Dienstplan — Datenblatt für die Datenschutzprüfung

Für die Prüfung durch Datenschutzbeauftragte und Träger. Beschreibt die technischen und organisatorischen Maßnahmen nach **Art. 32 DSGVO**.

Stand: Oktober 2026

Die wichtigste Aussage zuerst

Die Anwendung überträgt keine Daten an den Hersteller oder an Dritte. Sie läuft vollständig auf den Rechnern der Einrichtung und baut von sich aus keine Verbindung ins Internet auf — weder zur Installation noch im Betrieb, weder für Aktualisierungen noch für Statistiken.

Daraus folgt:

- **Verantwortlicher** im Sinne der DSGVO ist allein die Einrichtung.
- Ein **Auftragsverarbeitungsvertrag mit dem Hersteller ist nicht erforderlich**, weil dieser keine personenbezogenen Daten verarbeitet.
- Es gibt **keine Drittlandübermittlung**.

Welche Daten verarbeitet werden

KATEGORIE	INHALT
Beschäftigtendaten	Name, Wochenstunden, Qualifikation, Gruppenzugehörigkeit, Dienste, Abwesenheiten, Stunden- und Urlaubskonto, Passwort-Hash
Daten der betreuten Kinder	Name, Gruppenzugehörigkeit, Kennzeichnung „erhöhter Betreuungsbedarf", tageweise Zuordnung zu einer Betreuungsperson
Protokolle	Planänderungen (für die Rücknahme), An- und Abmeldeversuche

Mit der Abwesenheitsart „Krank" wird ein **Gesundheitsdatum nach Art. 9 DSGVO** verarbeitet: die Tatsache der Arbeitsunfähigkeit und ihr Zeitraum. Eine Diagnose, eine ärztliche Bescheinigung oder sonstige medizinische Angaben werden **weder erhoben noch gespeichert** — das Feld kennt nur die Art der Abwesenheit (Urlaub, Krank, Fortbildung, Sonderurlaub, unbezahlt). Rechtsgrundlage ist Art. 9 Abs. 2 lit. b DSGVO in Verbindung mit § 26 Abs. 3 BDSG — die Erfüllung arbeitsrechtlicher Pflichten.

Weitere besondere Kategorien werden nicht verarbeitet. Die Kennzeichnung „erhöhter Betreuungsbedarf" bei den Kindern ist eine Planungsgröße ohne diagnostische Angabe.

Technische Maßnahmen

Vertraulichkeit

Zugangskontrolle. Getrennte Anmeldung für Verwaltung und Mitarbeitende. Passwörter werden nie im Klartext gespeichert, sondern als **scrypt-Hash mit zufälligem Salz**. Mindestlänge acht Zeichen.

Schutz vor dem Durchprobieren. Nach **fünf Fehlversuchen** ist das Konto für **15 Minuten** gesperrt. Die Sperre wird vor der Passwortprüfung ausgewertet, damit die Antwortzeit keinen Rückschluss zulässt. Jeder Versuch wird protokolliert.

Sitzungen. Jede Anmeldung erhält einen eigenen Zufallswert (256 Bit). Sitzungen laufen automatisch ab — Verwaltung nach 12 Stunden, Mitarbeitende nach 30 Tagen — und lassen sich einzeln beenden. Die Verwaltung sieht, welche Geräte gerade angemeldet sind. Ein zurückgesetztes Passwort beendet alle Anmeldungen der betroffenen Person.

Zugriffskontrolle. Mitarbeitende sehen ihren eigenen Plan sowie ihr Stunden- und Urlaubskonto, nicht die der anderen. Änderungen am Plan sind ihnen nur als Antrag möglich; die Entscheidung trifft die Verwaltung.

Transportverschlüsselung. Im Einzelplatzbetrieb verlassen die Daten den Rechner nicht. Im Hausnetz-Betrieb läuft der gesamte Zugriff über **TLS 1.3**; der interne Server ist ausschließlich über die lokale Schleife erreichbar. Das Zertifikat erzeugt jede Installation selbst, mit eigenem privatem Schlüssel.

Trennungskontrolle. Gruppen sind voneinander getrennt; Dienste, Kinder und Zeiten gehören jeweils zu einer Gruppe.

Integrität

Eingabekontrolle. Jede Planänderung wird protokolliert — mit Zeitpunkt und der Angabe, ob sie durch die Verwaltung erfolgte. Änderungen sind rücknehmbar.

Plausibilitätsprüfungen. Ruhezeiten (§ 5 ArbZG), aufeinanderfolgende Arbeitstage (§ 9 ArbZG) und Nachtdienst-Kontingente werden geprüft und gemeldet. *Diese Prüfungen sind eine Arbeitshilfe und keine Rechtsberatung; die Verantwortung für den Dienstplan verbleibt beim Arbeitgeber.*

Verfügbarkeit und Belastbarkeit

Sicherung. Beim Start legt die Anwendung automatisch eine Sicherung an und bewahrt die letzten 30 Stände auf. Eine Sicherung lässt sich jederzeit von Hand auslösen.

Wiederherstellung. Die Datenbank ist eine einzelne Datei und kann durch Zurückspielen einer Sicherung wiederhergestellt werden.

Aktualisierungen. Bei einer neuen Fassung wird die Datenbank automatisch angepasst, vorher gesichert. Bestehende Daten bleiben erhalten.

Löschung und Aufbewahrung

DATUM	FRIST
Anmeldeversuche	90 Tage, danach automatisch gelöscht
Abgelaufene Sitzungen	werden automatisch entfernt
Beschäftigten- und Plandaten	von der Einrichtung gesteuert

Eine Person kann **vollständig gelöscht** werden, mitsamt Diensten, Abwesenheiten, Konten und Anmeldedaten — der Weg für eine Löschbitte nach Art. 17 DSGVO. Alternativ lässt sie sich deaktivieren, wenn die Historie erhalten bleiben muss.

Hinweis zur Aufbewahrung: Aufzeichnungen über die Arbeitszeit sind nach § 16 Abs. 2 ArbZG mindestens **zwei Jahre** aufzubewahren. Vor Ablauf dieser Frist ist Deaktivieren der richtige Weg, nicht Löschen.

Was die Einrichtung selbst leisten muss

Diese Punkte kann keine Software übernehmen. Ohne sie greifen die Maßnahmen oben nur zur Hälfte.

Festplattenverschlüsselung	Die Datenbank liegt unverschlüsselt auf dem Rechner. BitLocker bzw. FileVault einschalten — sonst genügt der Diebstahl des Geräts.
Physische Sicherung	Der Rechner gehört in einen Raum, zu dem nicht jeder Zutritt hat.
Netz	Im Hausnetz-Betrieb: eigenes Netz ohne Gastzugang, WLAN mindestens WPA2.
Berechtigungen	Das Verwaltungs-Passwort nur an die Personen, die es brauchen. Beim Ausscheiden Zugang entziehen.
Sicherungen auslagern	Die automatischen Sicherungen liegen auf demselben Rechner. Regelmäßig auf ein getrenntes, ebenfalls verschlüsseltes Medium kopieren.
Verarbeitungsverzeichnis	Die Verarbeitung ist im Verzeichnis nach Art. 30 DSGVO aufzunehmen. Dieses Datenblatt liefert die technischen Angaben dafür.
Information der Beschäftigten	Nach Art. 13 DSGVO über die Verarbeitung informieren. Je nach Haus ist der Betriebs- oder Personalrat zu beteiligen.

Grenzen, die wir offen benennen

- Die Daten in der Datenbank sind **nicht zusätzlich verschlüsselt**. Der Schutz liegt bei der Festplattenverschlüsselung des Betriebssystems.
- Das Zertifikat im Hausnetz-Betrieb ist **selbst ausgestellt**. Es verschlüsselt vollwertig, wird von Browsern aber erst nach einmaliger Hinterlegung ohne Warnung akzeptiert.

- Ein Zugriff **von außerhalb des Hauses** ist nicht vorgesehen und nicht unterstützt.
- Die Protokolle erfassen Planänderungen und Anmeldungen, **nicht jeden Lesezugriff**.

Fragen zu diesem Datenblatt beantwortet der Hersteller. Es ersetzt keine eigene Bewertung durch die oder den Datenschutzbeauftragten der Einrichtung.
